

DemoCorp 정보보호 지침서

문서번호: SEC - POL - 2025 - 003 / 시행일: 2025년 3월 1일 / 버전: 2.3

본 지침서는 회사의 정보자산 보호 및 「개인정보 보호법」 등 관련 법령 준수를 위한 정보보호 기준을 정의한다.

목차

제1장 총칙

제2장 정보보호 조직 및 책임

제3장 자산 관리

제4장 인적 보안

제5장 접근통제

제1절 사용자 계정 관리

제2절 사용자 식별 및 인증

제3절 비밀번호 관리

제4절 특수 계정 관리

제6장 암호화

제7장 물리적 보안

제5장 접근통제

제3절 비밀번호 관리

제15조 (비밀번호 작성규칙)

- ① 모든 사용자(개인정보취급자 포함) 및 정보주체(이용자)는 정보시스템 및 개인정보처리시스템에 대한 비밀번호를 다음 각 호에 따라 작성하여야 한다.
1. 영문, 숫자, 특수문자 중 2종류 이상을 조합하여 최소 10자리 이상으로 구성하거나, 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성한다. 복잡도 요구사항은 시스템적으로 강제한다.
 2. 생일, 전화번호, 주민등록번호 일부, ID와 유사한 문자열 등 추측이 쉬운 개인정보를 비밀번호로 사용하여서는 아니 된다.
 3. 동일한 문자의 반복(예: aaaa, 1111), 키보드 상 연속된 문자(예: qwerty, asdf), 연속된 숫자(예: 12345)는 사용을 제한한다.

제16조 (비밀번호 관리절차)

- ① 시스템 도입 시 또는 신규 계정 발급 시 설정된 초기 비밀번호 및 임시 비밀번호는 최초 로그인 시 강제로 변경하도록 시스템에 구현하여야 한다.
- ② 비밀번호 입력 및 변경 시 화면 마스킹 처리(asterisk 등)를 적용하여 어깨너머 노출을 방지한다.
- ③ 비밀번호를 종이, 파일, 모바일 기기 등에 기록·저장하는 행위를 원칙적으로 제한하며, 부득이한 경우 반드시 암호화하여 저장하여야 한다.
- ④ 침해사고 발생 또는 비밀번호 노출이 의심되는 경우 지체 없이 해당 비밀번호를 변경하여야 한다.
- ⑤ 비밀번호 분실 시 본인확인(이메일·휴대폰 인증 등)을 거친 후 안전한 절차에 따라 재발급한다. 재발급된 비밀번호는 임시 비밀번호로 처리하며 최초 로그인 시 강제 변경한다.
- ⑥ 비밀번호 유효기간을 설정하여 반기별 1회 이상 변경하도록 한다. 변경주기 도래 시 시스템에서 자동으로 변경을 강제한다.
- ⑦ 관리자(root, administrator 등) 비밀번호는 일반 사용자 비밀번호와 별도의 비밀등급으로 분류하여 관리하며, 봉인 보관 등 추가 보호 조치를 적용한다.
- ⑧ 비밀번호는 데이터베이스 저장 시 복호화가 불가능한 단방향 암호화 알고리즘(bcrypt, argon2, scrypt 등)으로 해시 처리하여 저장한다. MD5, SHA - 1 등 안전성이 검증되지 않은 알고리즘 사용을 금지한다.

제17조 (인증수단의 안전한 적용)

- ① 개인정보취급자 또는 정보주체의 인증수단으로 비밀번호 외에 다중인증(MFA), 인증서, OTP, 보안토큰, 생체인증 등을 추가로 적용할 수 있다.
- ② 관리자 계정 및 외부망에서 개인정보처리시스템에 접속하는 경우 MFA 적용을 필수로 한다.